

Marco integrativo GQM + PRAGMATIC para indicadores APT a nivel nacional (España)

1. Visión general

El método **Goal-Question-Metric (GQM)** conecta objetivos estratégicos con preguntas operativas y métricas cuantificables.

El marco **PRAGMATIC** aporta nueve atributos de calidad para validar que esas métricas sean útiles en la práctica.

Este documento describe cómo aplicar GQM + PRAGMATIC a los indicadores de Amenaza Persistente Avanzada (APT) definidos en el *Informe APT* para el contexto nacional español, garantizando trazabilidad desde los objetivos de la Estrategia de Seguridad Nacional hasta los datos técnicos que recoge la encuesta.

2. Objetivos nacionales (Goals) relacionados con APT

Código Goal	Descripción (objetivo nacional)
G1	Reducir el tiempo medio de detección (MTTD) de incidentes APT en infraestructuras críticas a ≤ 4 h para 2027.
G2	Limitar el tiempo medio de respuesta (MTTR) ante incidentes APT a ≤ 24 h para 2027.
G3	Disminuir el porcentaje de incidentes cuyo vector inicial es phishing a < 15 % del total de intrusiones confirmadas para 2027.
G4	Incrementar la cobertura de detección de TTPs MITRE ATT&CK asociadas a APT a ≥ 80 % en las organizaciones de importancia crítica para 2027.
G5	Garantizar que el ≥ 90 % de las vulnerabilidades críticas (CVSS ≥ 7) en activos esenciales se parcheen dentro de los 7 días posteriores a su publicación para 2027.
G6	Elevar el Índice Global de Madurez (IGM) de las entidades esenciales y importantes a $\geq 0,70$ (escala 0-1) para 2027.
G7	Mejorar el ROI medio de las inversiones en ciberseguridad frente a APT a $\geq 1,5$ (es decir, cada euro invertido evita 1,5 € de pérdidas esperadas) para 2027.

3. Derivación de preguntas (Questions)

Para cada Goal se formulan una o más preguntas que la encuesta debe responder.

Goal	Pregunta(s) derivada(s)
G1	P13.1: ¿Cuál es el tiempo medio de detección (MTTD) de incidentes APT en su organización?
G2	P13.2: ¿Cuál es el tiempo medio de respuesta (MTTR) ante incidentes APT?
G3	P13.4: ¿Qué porcentaje de los incidentes confirmados tuvo como vector inicial phishing?
G4	P22.1-22.5: ¿Qué nivel de capacidad de detección (0-3) tiene para cada una de las TTPs MITRE relevantes (System Information Discovery, Ingress Tool Transfer, Web Protocols, Credential Access, Lateral Movement)?
G5	P13.3: ¿Cuál es el tiempo medio de parcheo (MTTP) de vulnerabilidades críticas (CVSS ≥ 7) en activos críticos?
G6	P35: ¿Utiliza un Índice Global de Madurez (IGM) formal? P6-P15: preguntas de gobernanza, riesgo, inversión, etc., que alimentan el cálculo del IGM.
G7	P33-P36: preguntas sobre inversión anual (% TI), existencia de modelo ROI, influencia de incidentes en la inversión, etc.

4. Definición de métricas (Metrics) y aplicación de los criterios PRAGMATIC

Cada pregunta se convierte en una métrica cuantitativa o ordinal.

A continuación se muestra la plantilla que se usa para evaluar cada métrica bajo los nueve atributos PRAGMATIC.

Métri ca (deri vada de Preg unta)	Tipo	Fórm ula / Escal a	P (Pred ictivo)	R (Rele vante)	A (Acci onab le)	G (Gen uino)	M (Signi ficati vo)	A (Prec iso)	T (Opo rtun o)	I (Inde pend iente)	C (Rent able)	Com entar io brev e
MTT D (P13. 1)	Hora s	Valor direc to	Alto (dete cta tende ncia)	Alto (core)	Alto (disp ara accio nes de mejo ra)	Alto (basa do en datos SIEM)	Alto (imp acto en daño)	Alto (med ido con herra mien tas)	Alto (repo rte mens ual)	Medi o (dep ende de fuent es inter nas)	Medi o (cost o de herra mien tas)	Métri ca clave de detec ción
MTT R (P13. 2)	Hora s	Valor direc to	Alto	Alto	Alto	Alto	Alto	Alto	Alto	Medi o	Medi o	Métri ca de resp uesta
% Phish ing (P13. 4)	%	(inci dente s con phis hing / total incid entes)×10 0	Medi o	Alto	Alto	Alto	Alto	Alto	Alto	Alto	Bajo (fácil de obte ner)	Señal temp rana de inge nierí a socia l
Cobe rtura TTPs MITR E (P22. x)	Escal a 0-3	Prom edio de las cinco TTPs	Medi o-Alt o	Alto	Alto	Alto	Alto	Alto-Medi o (dep ende de herra mien tas)	Medi o-Alt o	Medi o	Medi o-Alt o	Refu erza detec ción basa da en comp orta mien to

MTT P (P13.3)	Días	Valor directo	Alto	Alto	Alto	Alto	Alto	Alto	Alto	Medio	Bajo (parqueo barato o si se automatiza)	Evita explotación rápida
IGM (P35 + cálculo)	Índice 0-1	Fórmula ponderada (ver guía)	Alto	Alto	Alto	Alto	Alto	Alto	Alto	Bajo (depende de agregación)	Bajo (costo de cálculo bajo)	Síntesis de madurez
ROI ciberseguridad (P33-P36)	Ratio	(Pérdida esperada evitada – Inversión) / Inversión	Medio	Alto	Alto	Alto	Alto	Medio (requiere estimaciones)	Medio	Bajo	Alto (justify inversión)	Vincula gasto con beneficio

Nota: En la **Matriz de Evaluación PRAGMATIC Completa** (archivo (b)) se detalla la puntuación (0-2 o ✓/☒) y la justificación para cada criterio por cada métrica.

5. Proceso de aplicación en la encuesta

1. Definir Goals a partir de la Estrategia de Seguridad Nacional y el Plan de Recuperación y Resiliencia.
2. Formular Questions directamente vinculadas a cada Goal (ver tabla 3).
3. Seleccionar/Definir Metrics que respondan a esas Questions (ver tabla 4).
4. Evaluar cada Metric con el checklist PRAGMATIC (archivo (b)).
5. Incorporar las métricas aprobadas en la encuesta (preguntas 13, 22, etc.) y en la plantilla de cálculo (archivo (e)).
6. Reportar resultados usando el IGM y el ROI, garantizando que cada número sea trazable a un Goal nacional mediante la cadena GQM – Question – Metric.

6. Vinculación con normas y marcos de referencia

Cada pregunta de la encuesta ya está mapeada a NIS2, NIST CSF 2.0, ISO 27001:2022, ENS/CCN-STIC y MITRE ATT&CK (ver archivo (d)).

El enfoque GQM + PRAGMATIC añade una capa de **trazabilidad objetivo-métrica** que asegura que lo que se mide realmente contribuye a los propósitos estratégicos nacionales y cumple con los requisitos de calidad exigidos por los marcos antes mencionados.